

Nessus Vulnerability Assessment Report

Target: Metasploitable2

Prepared for: *Cybersecurity & Ethical Hacking Internship Program*

| Prepared by: *Debika Goswami* | Date: *11-09-2026*

1. Executive Summary

This report documents a vulnerability assessment conducted against Metasploitable2, an intentionally vulnerable Linux virtual machine used for security training, within an isolated VMware Host-Only lab network. The assessment was performed to identify, classify, and prioritize security weaknesses on the target host using an automated vulnerability scanner, and to compare those results against manual reconnaissance performed earlier with Nmap.

The scan was authorized and conducted entirely within a closed lab environment with no connectivity to production systems, consistent with the intended use of Metasploitable2 as a deliberately insecure training target.

Findings by Severity

Severity	Number of Findings
Critical	4
High	3
Medium	3
Low	1
Informational	1

2. Scope

Scanner	[e.g., Nessus Essentials v10.x / Tenable Nessus]
Target	Metasploitable2
Target IP	192.168.23.130
Attacker/Scanner IP	192.168.23.129
Network	VMware Host-Only (isolated, no external connectivity)
Scan Date	11-09-2026

Authorization	Lab exercise — self-authorized isolated environment
---------------	---

3. Methodology

Target Discovery

The Metasploitable2 VM was powered on within the VMware Host-Only network and its IP address confirmed via the VM console (ifconfig) and cross-verified with an Nmap host discovery/ping sweep (e.g., `nmap -sn 192.168.23.0/24`) from the attacker/scanner host on the same host-only segment.

Vulnerability Scanner Configuration

Nessus (or OpenVAS/GVM) was installed on the scanning host and licensed/activated. A new scan policy was created using a Basic Network Scan template, with the target field set to the Metasploitable2 IP address and default plugin families enabled for a comprehensive, non-credentialed assessment.

Scan Type

A full, non-credentialed vulnerability scan was performed, covering all TCP ports and standard service/version detection plugins. [Note whether credentialed scanning, e.g., SSH credentials, was also used — Metasploitable2's default credentials (msfadmin/msfadmin) can optionally be supplied for deeper local checks.]

Vulnerability Assessment

The scanner enumerated open ports and services, fingerprinted software versions, and matched them against its vulnerability plugin database, correlating findings to known CVEs where applicable.

Severity Classification

Findings were classified using the scanner's native severity ratings (Critical / High / Medium / Low / Informational), which are derived from CVSS base scores, consistent with industry-standard risk categorization.

Result Analysis

Scan output was manually reviewed to validate findings, remove false positives, and cross-reference open ports/services against the earlier Nmap service scan of the same host to confirm consistency between reconnaissance and vulnerability-scan results (see Section 6).

4. Vulnerability Summary

Severity	Number of Findings
Critical	4
High	3
Medium	3
Low	1

Severity	Number of Findings
Informational	1

5. Detailed Findings

The following findings represent the vulnerabilities most characteristic of a default Metasploitable2 build. Confirm each against your own scan output, and adjust host/port/evidence fields to match your actual results before submission.

F-01: VSFTPD v2.3.4 Backdoor Command Execution

Severity	Critical
CVSS	10.0 (CVSS v2) / 9.8 (CVSS v3 equivalent)
Host	192.168.23.130
Port	21/tcp
Service	ftp (vsftpd 2.3.4)

Description

The installed version of vsftpd (2.3.4) is a maliciously trojaned release distributed briefly in 2011. Sending a username containing the sequence ":" to the FTP service triggers a backdoor that opens a root command shell on TCP port 6200, giving an unauthenticated attacker direct root access to the host.

Evidence

Nessus Plugin ID 55523 - VSFTPD Smiley Face Backdoor

Nmap: 21/tcp open ftp vsftpd 2.3.4

Manual verification: USER user:) -> listener spawned on port 6200/tcp

Impact

Complete, unauthenticated remote compromise of the host with root-level privileges. This is the single most severe finding on the system and should be treated as a full breach scenario.

Remediation

- Immediately remove or replace vsftpd 2.3.4 with a current, vendor-supported release
- Verify package checksums against the official vsftpd source going forward
- Disable anonymous/unauthenticated FTP if not explicitly required
- Isolate the host from production networks until remediated

Reference: CVE-2011-2523; Rapid7 Metasploit module exploit/unix/ftp/vsftpd_234_backdoor

F-02: UnrealIRCd Backdoor Command Execution

Severity	Critical
CVSS	10.0 (CVSS v2) / 9.8 (CVSS v3 equivalent)

Host	192.168.23.130
Port	6667/tcp
Service	irc (UnrealIRCd)

Description

The Unreal3.2.8.1.tar.gz distribution used by this host was compromised at the source and contains a backdoor. Any data sent to the IRC listener beginning with "AB;" is executed as a system command with the privileges of the IRC daemon.

Evidence

Nessus Plugin ID 43093 - UnrealIRCd Backdoor Detection

Nmap: 6667/tcp open irc UnrealIRCd

Impact

Unauthenticated remote code execution as the service account running the IRC daemon, typically usable as a pivot to further privilege escalation.

Remediation

- Remove the compromised UnrealIRCd build and reinstall from a verified, current source
- Restrict IRC service exposure to trusted network segments only
- Monitor for outbound connections initiated by the IRC service account

Reference: CVE-2010-2075

F-03: Java RMI Registry Insecure Default Configuration (RCE)

Severity	Critical
CVSS	9.8 (CVSS v3 equivalent)
Host	192.168.23.130
Port	1099/tcp
Service	java-rmi

Description

The Java RMI registry service accepts remote class-loading calls, allowing an unauthenticated attacker to invoke arbitrary methods and achieve remote code execution via the well-known RMI registry exploit chain.

Evidence

Nessus Plugin ID 51988 - Java RMI Server Insecure Default Configuration RCE

Nmap: 1099/tcp open java-rmi

Impact

Unauthenticated remote code execution on the host.

Remediation

- Do not expose the RMI registry to untrusted networks

- Upgrade to a Java Runtime version that enforces class-loading restrictions
- Bind RMI services to localhost or a management-only interface

Reference: CVE-2011-3556

F-04: distcc Remote Code Execution

Severity	Critical
CVSS	9.8 (CVSS v3 equivalent)
Host	192.168.23.130
Port	3632/tcp
Service	distccd

Description

distccd is running without access controls. distcc's design trusts the compilation requests it receives, allowing an unauthenticated remote attacker to execute arbitrary commands on the host.

Evidence

Nessus Plugin ID 34090 - Distcc Detection

Nmap: 3632/tcp open distccd

Impact

Unauthenticated remote code execution with the privileges of the distccd process.

Remediation

- Disable distccd on production or externally reachable systems
- If required for a build farm, restrict access via firewall to trusted build hosts only
- Run distccd with --allow restrictions and least-privilege service accounts

Reference: CVE-2004-2687

F-05: NFS Share Exported with Insecure Permissions

Severity	High
CVSS	7.5
Host	192.168.23.130
Port	2049/tcp, 111/tcp
Service	nfs / rpcbind

Description

The host exports NFS shares (e.g., /) with no host-based access restriction, allowing any client on the network to mount the filesystem and read or write files, including potentially sensitive system paths.

Evidence

Nessus Plugin ID 11356 - NFS Share Export List

showmount -e [Target IP] -> / (everyone)

Impact

Unauthorized read/write access to exported filesystems; potential for data theft, tampering, or planting files that lead to further compromise.

Remediation

- Restrict NFS exports to specific trusted host IP ranges in /etc/exports
- Apply root_squash and read-only exports where write access is not required
- Firewall rpcbind/NFS ports from untrusted networks

Reference: CWE-732: Incorrect Permission Assignment for Critical Resource

F-06: Samba Vulnerable to Remote Code Execution (usermap_script)

Severity	High
CVSS	9.8
Host	192.168.23.130
Port	139/tcp, 445/tcp
Service	netbios-ssn / microsoft-ds (Samba)

Description

The installed Samba version (3.x) is vulnerable to a shell-metacharacter injection flaw in the "username map script" configuration option, allowing arbitrary command execution.

Evidence

Nessus Plugin ID 63459 - Samba Username Map Script Command Execution

Nmap: 139/tcp, 445/tcp open netbios-ssn Samba smbd 3.X

Impact

Unauthenticated remote code execution as root in default Metasploitable2 configurations.

Remediation

- Upgrade Samba to a patched, currently supported release
- Remove or disable the username map script configuration option
- Restrict SMB access to trusted internal hosts only

Reference: CVE-2007-2447

F-07: Rlogin / Rsh / Rexec Cleartext Remote Login Services

Severity	High
CVSS	7.5
Host	192.168.23.130

Port	512/tcp, 513/tcp, 514/tcp
Service	exec, login, shell (r-services)

Description

The legacy BSD r-services are enabled and permit authentication based on host/user trust relationships (.rhosts) and transmit credentials and session data in cleartext.

Evidence

Nessus Plugin ID 10205 - rlogin Service Detection

Nmap: 512/tcp exec, 513/tcp login, 514/tcp shell

Impact

Credential interception via network sniffing and potential authentication bypass through host-based trust abuse.

Remediation

- Disable rlogin/rsh/rexec entirely
- Replace with SSH for all remote administration
- Audit and remove any .rhosts / hosts.equiv trust configurations

Reference: CWE-319: Cleartext Transmission of Sensitive Information

F-08: Unencrypted Telnet Service Enabled

Severity	Medium
CVSS	5.9
Host	192.168.23.130
Port	23/tcp
Service	telnet

Description

Telnet is enabled and transmits authentication credentials and session traffic in cleartext, allowing interception by anyone able to observe network traffic.

Evidence

Nessus Plugin ID 42263 - Unencrypted Telnet Server

Nmap: 23/tcp open telnet

Impact

Credential and session disclosure to a network-position attacker (e.g., ARP spoofing on the same segment).

Remediation

- Disable telnetd and replace with SSH
- If telnet must remain for lab purposes, restrict to an isolated management VLAN

Reference: CWE-319: Cleartext Transmission of Sensitive Information

F-09: MySQL and PostgreSQL Accessible with Weak/Default Credentials

Severity	Medium
CVSS	6.5
Host	192.168.23.130
Port	3306/tcp, 5432/tcp
Service	mysql, postgresql

Description

Both database services are reachable from the network and accept weak or default credentials (e.g., MySQL root with no password; PostgreSQL 'postgres' account with a default password).

Evidence

Nessus Plugin ID 10719 - MySQL Unpassworded Account Check

Nmap: 3306/tcp open mysql, 5432/tcp open postgresql

Impact

Unauthorized access to application data, and potential use of database functions (e.g., MySQL UDFs) as a stepping stone to command execution.

Remediation

- Set strong, unique passwords for all database accounts
- Bind database services to localhost or an application-only network segment
- Remove default/sample accounts and databases

Reference: CWE-521: Weak Password Requirements

F-10: Apache Tomcat Default/Weak Manager Credentials

Severity	Medium
CVSS	6.8
Host	192.168.23.130
Port	8180/tcp
Service	http (Apache Tomcat/Coyote)

Description

The Tomcat Manager application is reachable and accepts default credentials (tomcat/tomcat), allowing deployment of a malicious WAR file for remote code execution.

Evidence

Nessus Plugin ID 12085 - Apache Tomcat Default Credentials

Nmap: 8180/tcp open http Apache Tomcat/Coyote JSP engine

Impact

Authenticated remote code execution via WAR file deployment through the Manager interface.

Remediation

- Change or remove default Tomcat Manager credentials
- Restrict Manager application access to localhost/admin network only
- Upgrade Tomcat to a current, supported version

Reference: CWE-798: Use of Hard-coded Credentials

F-11: X11 Server Access Control Disabled

Severity	Low
CVSS	3.7
Host	192.168.23.130
Port	6000/tcp
Service	x11

Description

An X11 server is listening and is configured without access control, which can allow keystroke capture or window manipulation from a remote client under some configurations.

Evidence

Nessus Plugin ID 10407 - X Server Detection

Nmap: 6000/tcp open X11

Impact

Potential information disclosure or session interference if a client connects without restriction.

Remediation

- Disable X11 forwarding/listening on servers that do not require a GUI
- Enable xhost access controls if X11 must remain enabled

Reference: CWE-284: Improper Access Control

F-12: SSL/TLS and Service Banner Information Disclosure

Severity	Informational
CVSS	N/A
Host	192.168.23.130
Port	Multiple
Service	Various

Description

Several services return verbose banners disclosing exact software name and version (e.g., vsftpd 2.3.4, Apache 2.2.8, OpenSSH 4.7p1), which simplifies vulnerability targeting for an attacker.

Evidence

Nessus Plugin ID 10267 - SSH Server Type and Version Information

Various banner-grab findings across scanned ports

Impact

Low direct risk, but banner information materially speeds up an attacker's reconnaissance and exploit-selection process.

Remediation

- Suppress or minimize service banners where feasible
- Treat as a defense-in-depth item rather than a standalone priority

Reference: CWE-200: Exposure of Sensitive Information

6. Risk Analysis

Remediation priority should follow exploitability and impact, not just the scanner's raw severity label:

- Priority 1 — Unauthenticated RCE (F-01 VSFTPD backdoor, F-02 UnrealIRCd backdoor, F-03 Java RMI, F-04 distcc): these four findings each allow an anonymous attacker to obtain command execution with no credentials at all. They represent the shortest, most reliable path to full compromise and must be remediated first.
- Priority 2 — Authenticated/network-position RCE and unrestricted data access (F-05 NFS, F-06 Samba): these require either a foothold or default trust assumptions, but Samba's `usermap_script` flaw is trivially reachable and NFS misconfiguration allows direct filesystem tampering.
- Priority 3 — Cleartext protocols and weak/default credentials (F-07 r-services, F-08 telnet, F-09 database credentials, F-10 Tomcat manager): these lower the bar for an attacker who already has network visibility or a partial foothold, and should be remediated alongside Priority 1–2 items.
- Priority 4 — Lower-impact and informational items (F-11 X11, F-12 banner disclosure): address as part of general hardening once higher-severity issues are closed.

The concentration of unauthenticated root-level RCE vulnerabilities is what drives the overall posture to Critical; a single successful exploitation of any Priority 1 finding results in full host compromise, so partial remediation of only lower-severity items would not materially reduce risk.

7. Recommendations

- Patch or replace vulnerable applications (vsftpd, UnrealIRCd, Samba, Tomcat) with current, vendor-supported versions.
- Remove unnecessary services (distccd, r-services, X11, telnet) that provide no required business function.
- Disable insecure protocols (telnet, rsh/rlogin/rexec, unauthenticated RMI) in favor of encrypted, authenticated alternatives such as SSH.
- Restrict network access to administrative and database services using host-based and network firewall rules.

- Implement firewall rules limiting inbound access to only the ports/services required for the host's function.
- Strengthen authentication by eliminating default and blank-password accounts (MySQL root, PostgreSQL postgres, Tomcat manager).
- Segment sensitive systems (databases, management interfaces) onto a restricted VLAN separate from general user traffic.
- Replace obsolete software with maintained releases and establish a regular patch-management cadence.
- Continuously monitor critical systems with logging/alerting for authentication attempts and anomalous service usage.

8. Conclusion

Metasploitable2, as scanned, presents an extremely poor security posture, consistent with its purpose as an intentionally vulnerable training platform. The assessment identified multiple unauthenticated, root-level remote code execution vulnerabilities alongside numerous cleartext protocols, default credentials, and unrestricted service exposures. In a production context, this vulnerability profile would represent an imminent and near-certain compromise scenario. The exercise demonstrates the value of automated vulnerability scanning as a complement to manual reconnaissance (Nmap), and reinforces core hardening principles: minimize attack surface, eliminate default credentials, enforce encrypted protocols, and patch promptly.